# PROOF OF CONCEPT (PoC)

---

### 01 - Authentication Bypass via SQL Injection

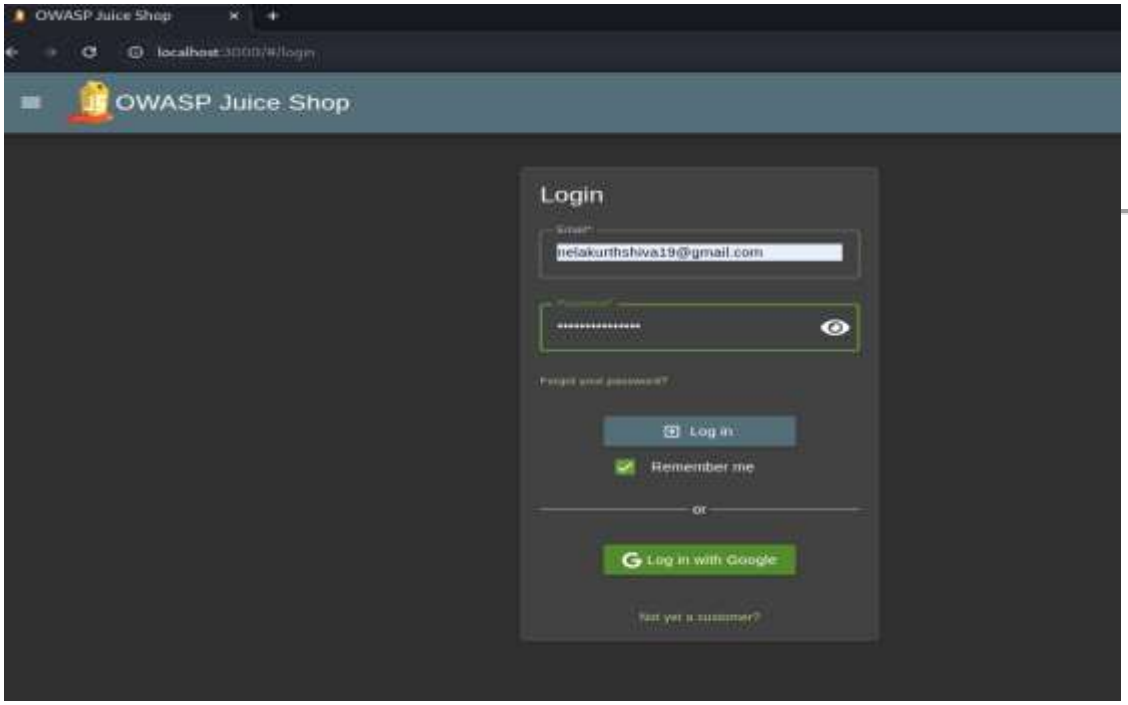
**Description:**
The login functionality of the application is vulnerable to SQL Injection due to improper input validation. The application directly processes user-supplied input in the email field without sanitization, allowing manipulation of the backend SQL query.

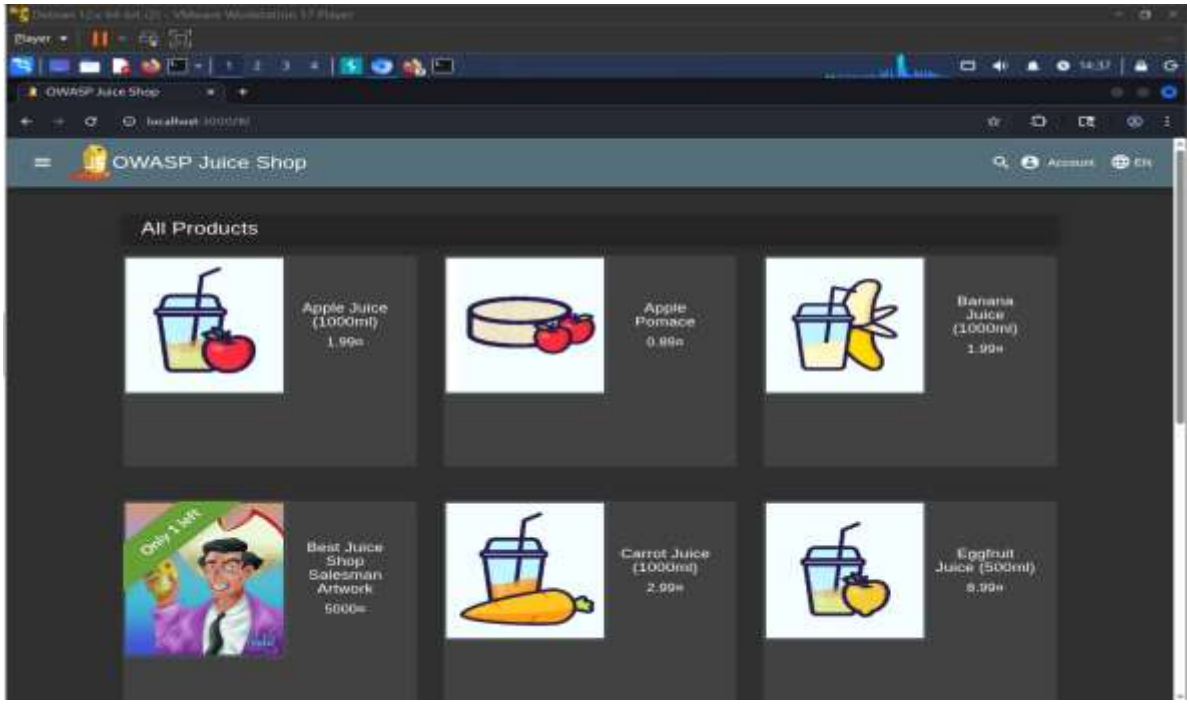
**Impact (High Risk):**
An attacker can bypass authentication and gain administrative access without valid credentials, leading to full system compromise.

**Steps to Reproduce:**

1. Navigate to the login page: http://localhost:3000/#/login
2. Enter the following payload in the Email field:
   ' OR 1=1 --
3. Enter any random password (e.g., test)
4. Click on **Log In**
5. Observe successful login without valid credentials

**Screenshot Explanation:**






## 02 - Cross-Site Scripting (XSS)

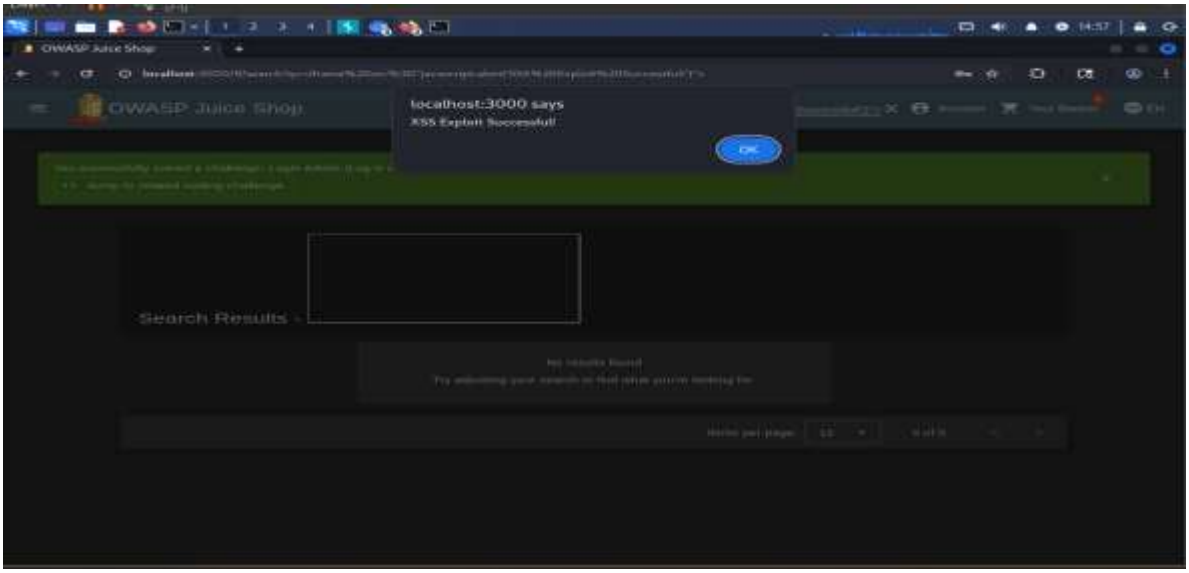
**Description:**
The application is vulnerable to Cross-Site Scripting (XSS), where user input is not properly sanitized before being rendered in the browser. This allows execution of malicious JavaScript code.

**Impact (High Risk):**
Attackers can execute scripts in the victim's browser, leading to session hijacking, data theft, or phishing attacks.

**Steps to Reproduce:**

1. Navigate to the search bar in the application
2. Enter the following payload:
   <iframe src="javascript:alert('XSS Exploit Successful!')">
3. Submit the search request
4. Observe that a JavaScript alert is executed

**Screenshot Explanation:**




**03 - Sensitive Data Exposure (Exposed /ftp Directory)**

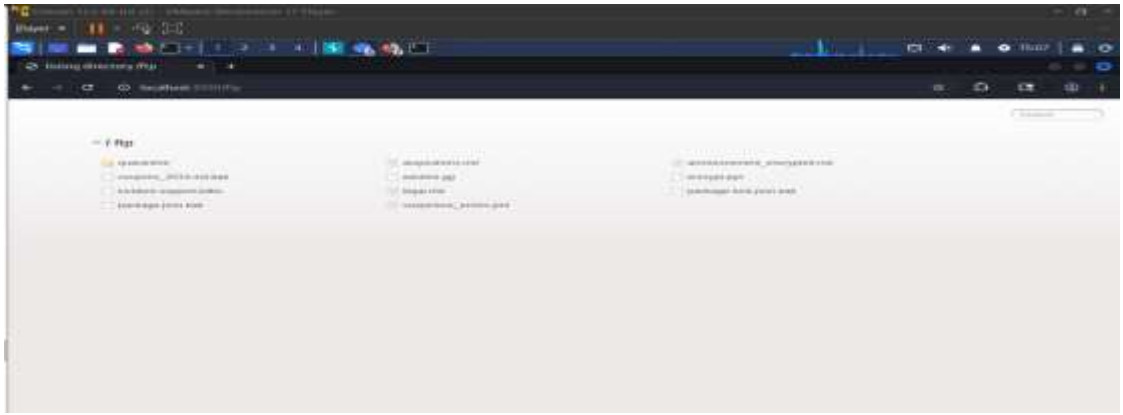
**Description:**
The application exposes sensitive files through an unprotected /ftp directory, allowing unauthorized users to access confidential data.

**Impact (Medium Risk):**
Sensitive files such as backups and configuration data may be accessed by attackers, potentially leading to further exploitation.

**Steps to Reproduce:**

1. Open browser and navigate to: http://localhost:3000/ftp
2. Browse the available files
3. Access downloadable files without authentication

**Screenshot Explanation:**



## 04 - Broken Authentication (No Rate Limiting)

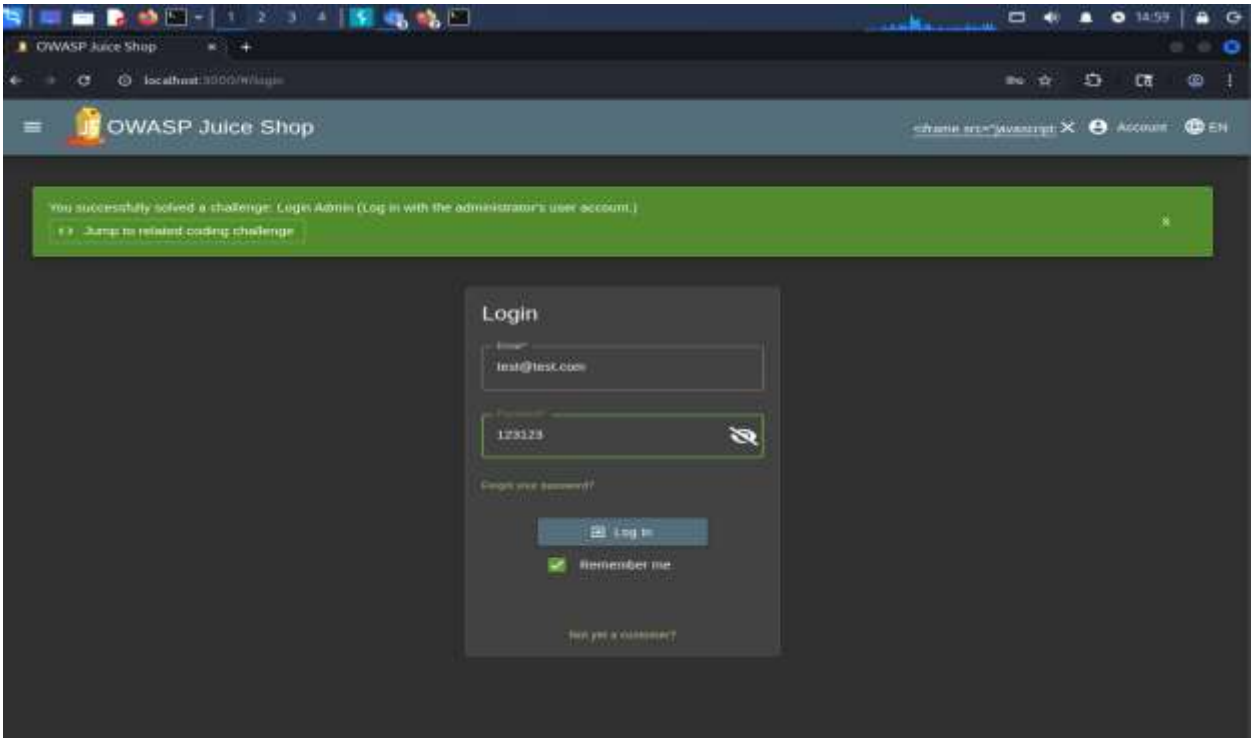
**Description:**
The application does not implement rate limiting or account lockout mechanisms, allowing unlimited login attempts.

**Impact (Medium Risk):**
Attackers can perform brute-force attacks to guess user credentials.

**Steps to Reproduce:**

1. Navigate to login page
2. Attempt multiple login requests with different passwords
3. Observe that no restrictions or delays are applied

**Screenshot Explanation:**




## 05 - Security Misconfiguration

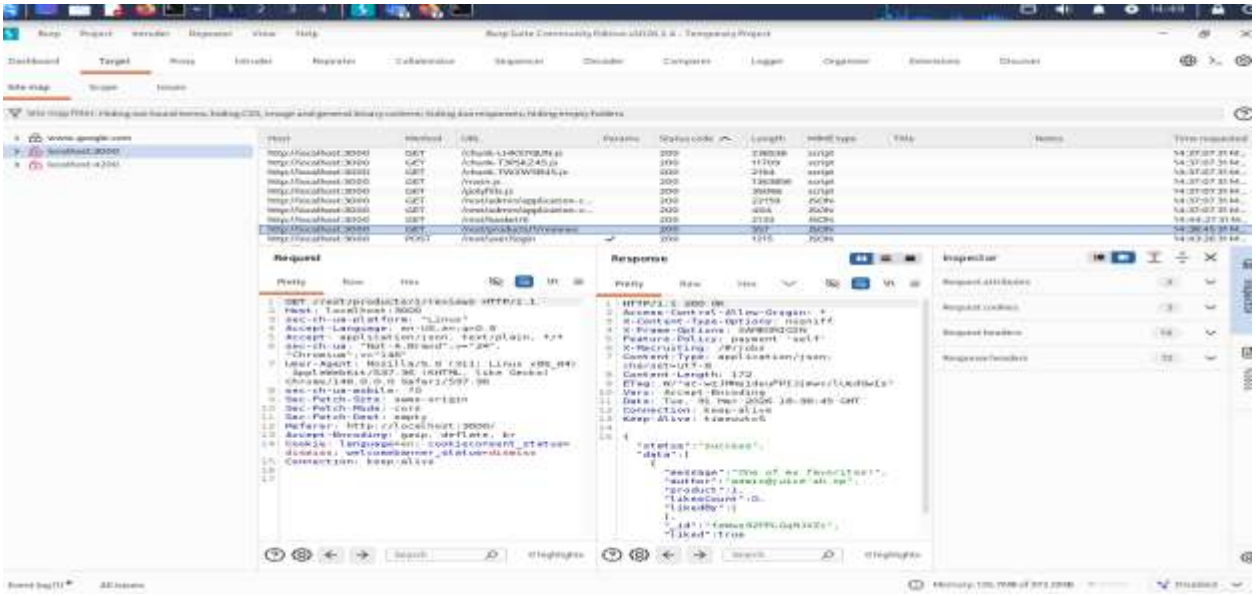
**Description:**
The application reveals excessive information through HTTP responses and error messages, indicating improper security configuration.

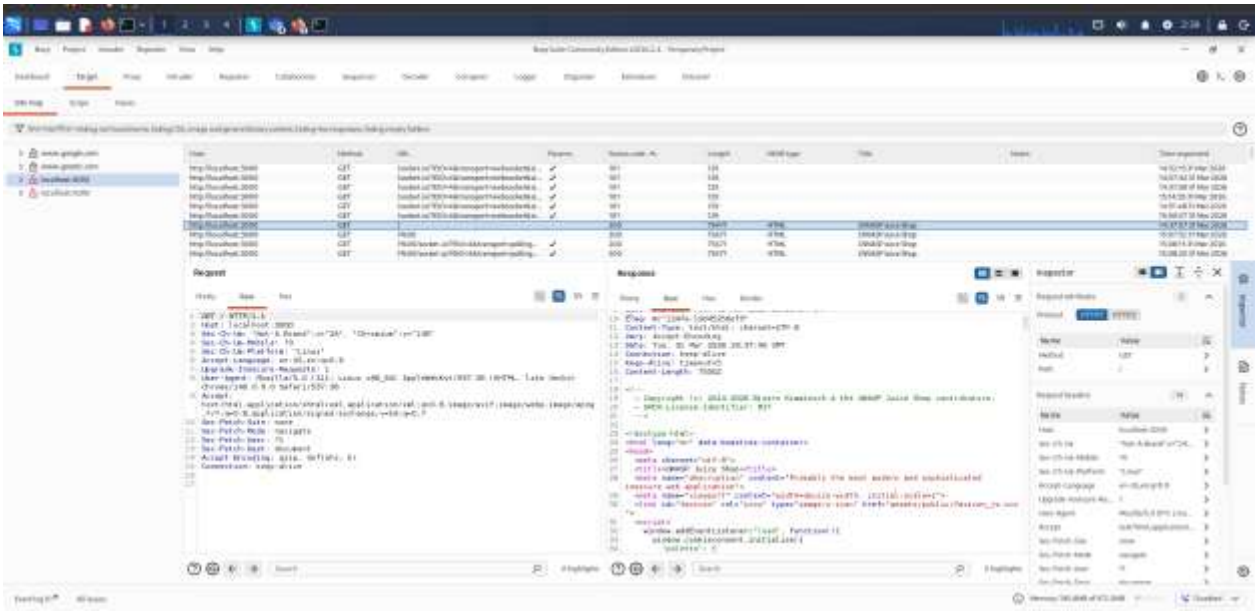
**Impact (Low Risk):**
Attackers can use this information to understand system architecture and craft targeted attacks.

**Steps to Reproduce:**

1. Intercept a request using Burp Suite
2. Analyze the HTTP response
3. Observe exposed headers and internal details

**Screenshot Explanation:**





## 06 - Broken Access Control

**Description:**
The application fails to properly enforce access control restrictions, allowing unauthorized users to access administrative endpoints.

**Impact (High Risk):**
Attackers can access restricted data and perform privileged actions without authorization.

**Steps to Reproduce:**

1. Intercept a request in Burp Suite
2. Modify header or request parameter:

X-User-Email: ' OR 1=1--

3. Forward the request
4. Observe access to admin-level data

**Screenshot Explanation:**

## Conclusion:

The Proof of Concept successfully demonstrated that multiple critical vulnerabilities exist and can be exploited with simple techniques. These findings confirm serious weaknesses in input validation, authentication, and access control mechanisms. Immediate remediation is required to prevent potential real-world attacks.